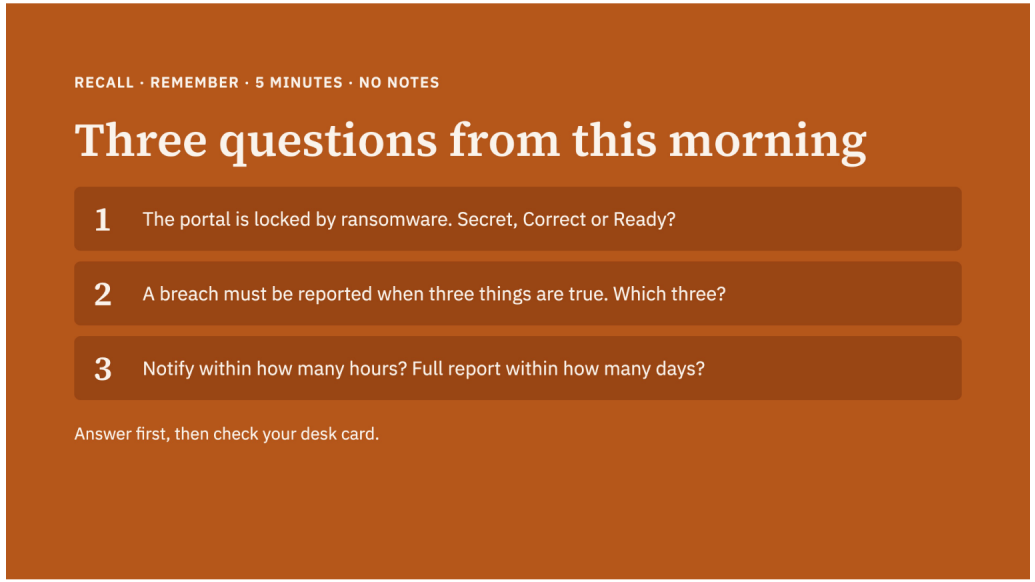
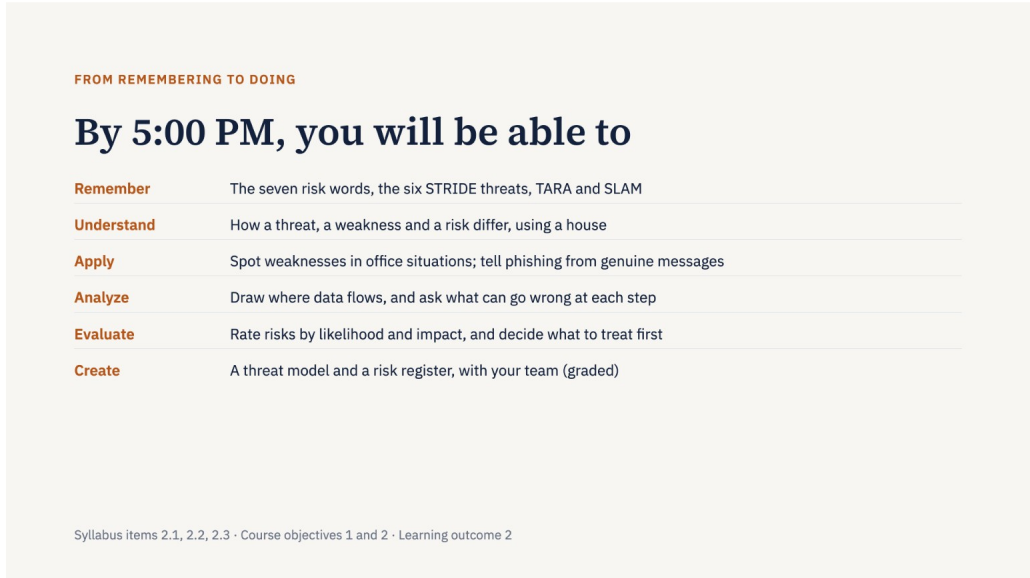
TIME: 1 minute. SAY: Welcome back. This morning we learned who attacks offices like ours and what the law expects of us. This afternoon we get practical: we find the weak spots before an attacker does, we predict where attacks are most likely to come from, and we learn to spot the tricks aimed at people. At 3:50 your team uses all of it in the graded risk assessment. Keep the same teams and the same RSSO story from this morning.




TIME: 5 minutes. RETRIEVAL: Ask all three before anyone looks at notes. Recalling after a break is what fixes this morning in memory. Face-to-face: teams agree an answer in 30 seconds, then call it out. Online: a three-question poll, or answers typed in the chat on your signal. ANSWERS: 1. Ready (availability) is hit first. If the attackers also steal files, Secret is hit too, as in this morning's 2023 case. 2. The 3S test: Sensitive (sensitive personal information, or information that could enable identity fraud), Stolen (there is reason to believe an unauthorized person got it), and Serious (a real risk of serious harm to the people affected). 3. The 72-5 rule: notify the NPC and the people affected within 72 hours of knowing, or reasonably believing, that a breach happened; send the full report within 5 days. WATCH FOR: anyone who says notification waits until the investigation is certain. Correct it gently: reasonable belief is enough. LINK: This morning was about what happens after a breach. This afternoon is about before: where could a breach happen at the RSSO, how likely is it, and what do we fix first?

TIME: 2 minutes. SAY: Same teams as this morning, and the same fictional office. Walk the timetable. PREVIEW THE GRADED TASK: at 3:50 your team builds a threat model and a risk register for the RSSO Assistance Portal, worth 20 percent of the course grade. The scenario, templates and rubric are in your learner guide. Everything before 3:50 is a tool for that task, so mark the templates as we go. Quiz 2 at 3:35 covers 2.1 to 2.3: 12 items in 15 minutes, worth 10 percent. ONLINE: breakout rooms are the same as this morning. REMIND: if your team made a data map in Bring it home this morning, keep it open; it helps in the risk assessment.




TIME: 2 minutes. SAY: The same ladder as this morning, from remembering to creating. The words on the first line are this afternoon's anchors: the house, STRIDE, TARA and SLAM. They go on your desk card at the end of the day. The last line is the graded task: by 4:45 every team will have created a threat model and a risk register for the RSSO. TIP: The learner guide has Check yourself questions after each lesson. Ask participants to try recalling the answer before looking; the effort of recalling is what makes it stick.

TIME: 5 minutes. SAY: Four words first, with a picture everyone knows. Picture your house. The asset is the house and everything inside it. The threat is a burglar. The vulnerability is the window you left unlocked. The control is the lock, the grille or the dog. Now the same four words at the RSSO. The asset is the applicant database. The threat is a criminal group that wants ID numbers. The vulnerability is an admin page that anyone on the internet can reach, still using the vendor's default password. The control is a strong unique password, multi-factor authentication, and no admin page open to the public. ASK: In your own office, what is one valuable asset, and what is one unlocked window? Take two answers from non-IT participants first, and keep them anonymous. WATCH FOR: people who call the burglar the risk. The burglar is the threat; the risk is the chance and size of the loss, which is the next slide. KEY POINT: We cannot stop criminals from existing, but we can lock the window. Most of our power is in removing weaknesses.

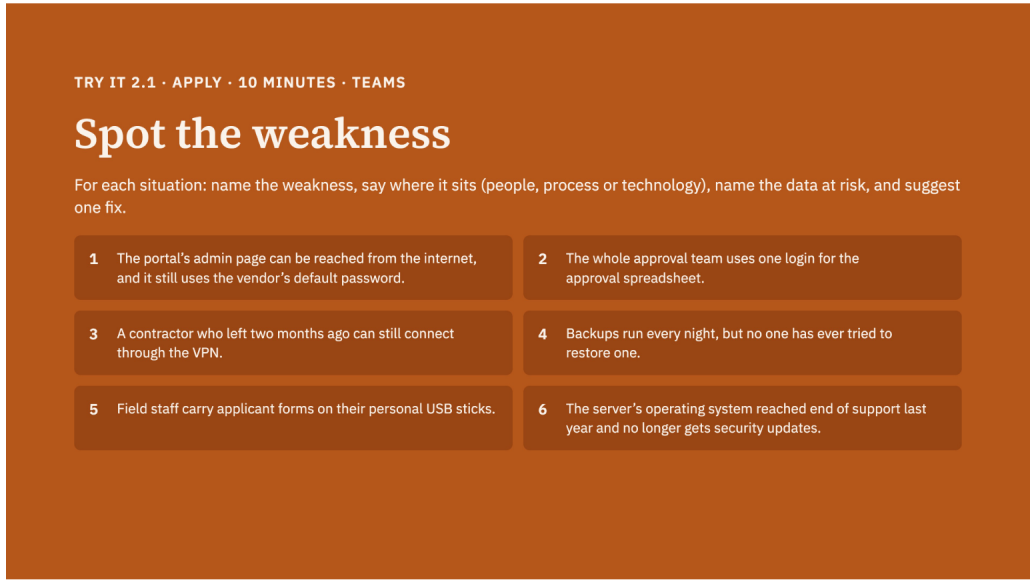
TIME: 4 minutes. SAY: A threat and a weakness together make a risk, but risks are not equal, so we rate each one on two things. Likelihood is how probable it is: for a house, how often burglars try your street; for the RSSO, how often pages like that exposed admin page are attacked. Often, because attackers use automated tools that search the internet for exposed login pages. Impact is how bad it would be: for the RSSO, the sensitive data of 48,000 people exposed, which this morning's law makes a notifiable breach. Put the two together and you have the risk. In 2.2 we turn this into a score from 1 to 25. KEY POINT: Read the dark box aloud. No weakness, no risk, even if threats exist. ASK: Which is easier for an office to change, the number of criminals in the world or its own weaknesses? (Its own weaknesses.) LINK: This is why the next slides are all about finding weaknesses.

TIME: 5 minutes. SAY: Weaknesses are not only technical. Walk the three cards. People: shared accounts mean no one is accountable for what happens in them; untrained staff click; passwords end up on sticky notes. Process: no routine to remove access when someone leaves; backups that have never been test-restored, so no one knows whether they work; no check before payment details are changed. Technology: systems that are unpatched or out of support, default passwords, admin pages open to the internet, files shared by public link, old website plugins, unencrypted laptops and USB sticks, one flat network where every computer can reach every other one, and lapsed security licences. This morning's 2023 case had one of these: an antivirus subscription that had expired months before the attack. PLAIN WORDS: end of support means the maker no longer releases security fixes, so every weakness found from then on stays open. ASK: Which card holds the weakness you see most often in offices like yours? Take one answer per card. WATCH FOR: the idea that security is only IT's job. People and process weaknesses are fixed by managers and staff. Non-IT participants often spot them first.

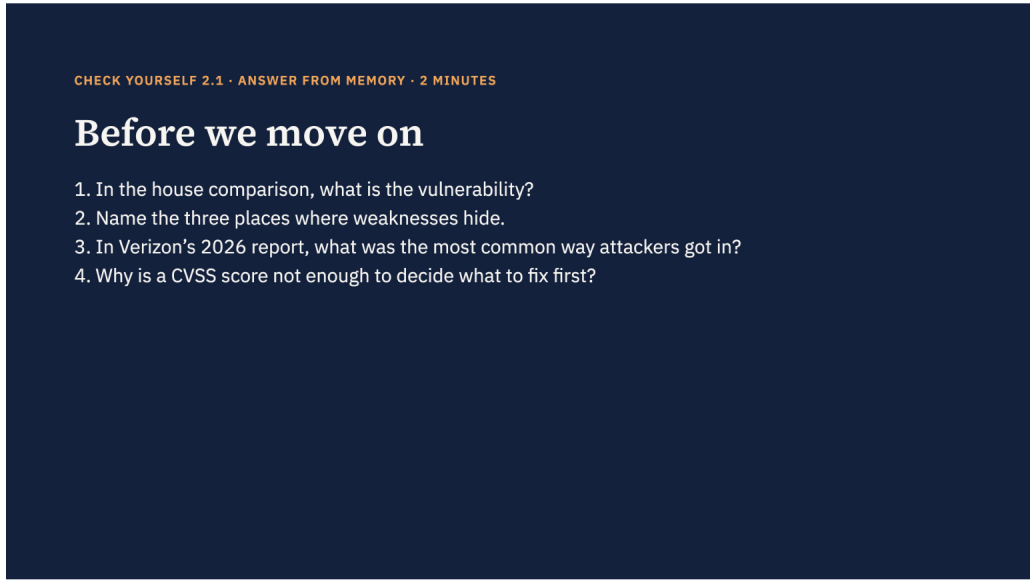
TIME: 4 minutes. SAY: These numbers come from Verizon's 2026 Data Breach Investigations Report, which studied more than 22,000 confirmed breaches in 145 countries. It is one of the largest yearly studies of real breaches. 31 percent: exploiting a vulnerability overtook stolen passwords as the most common way in; stolen credentials were 13 percent. In plain words, attackers increasingly climb through unlocked windows. 43 days: for weaknesses that attackers are known to be actively using, the most urgent kind, the median time to fix rose to 43 days, up from 32, and only about a quarter were fully fixed. Attackers do not wait that long. 48 percent: nearly half of breaches involved a third party such as a vendor or partner, up from 30 percent a year earlier. The RSSO's SMS vendor and e-wallet provider are part of its risk. ASK: Who in your office decides when security updates are installed? Who checks what your vendors do with your data? LINK: From this morning: under the DPA, the office stays accountable for personal data that its vendors process for it.

TIME: 5 minutes. SAY: Four habits. One, know what you have. You cannot protect a server or a spreadsheet you do not know exists; ISO 27001 calls this the inventory of information and other associated assets, control 5.9. Two, patch on a schedule: install security updates regularly, and fastest for weaknesses that attackers are known to be using. Renew security licences before they lapse, as the 2023 case taught us. Three, test only with permission. Scanning or probing a system without authority can be illegal access under the Cybercrime Prevention Act, RA 10175. Only authorized staff or contractors test, and only with written authority. This returns on Day 2, when we audit a training application under written rules of engagement. Four, scores are an input, not the decision. CVSS, the Common Vulnerability Scoring System, rates how technically severe a weakness is, from 0 to 10. A Medium weakness on the server that holds 48,000 records may matter more than a High one on a test machine with no data. ASK: In your office, who keeps the list of systems, and when was it last updated? IT DEPTH (optional): take one published weakness with its CVSS score and ask what it would cost the RSSO if exploited; the business impact can change the order of fixing. IF RUNNING LATE: skip the IT depth.

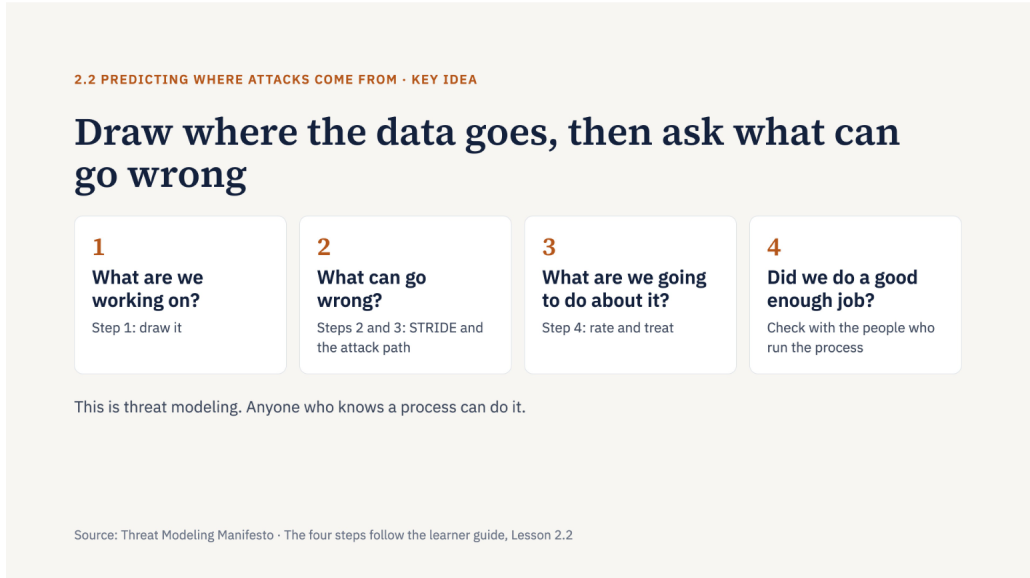
TIME: 5 minutes. SAY: Personal data has a life, from the moment we collect it to the day we dispose of it, and it is most at risk where it moves or is copied. Walk the six stages left to right. Ask the room for an example of each leak before you read it. Collect: forms that ask for more than the purpose needs; the rule is Little, this morning's proportionality principle. Store: spreadsheets saved on desktops, and unencrypted laptops. Use: shared logins, and screens that visitors can read over a clerk's shoulder. Share: email attachments, chat groups, public links and vendor exports; share only with those entitled to the data, through approved and secure channels. Keep: old copies forgotten in backups and test systems; keep data only as long as it is needed. Dispose: printouts in the trash, and old drives sold or thrown away; shred paper, and wipe or destroy drives. Improper disposal is a crime under Section 27 of the DPA. LINK: This morning's government rule applies at Store and Share. Sensitive data accessed off-site needs the head's approval, at most 1,000 records at a time, and encryption (Section 23). ASK: At which stage does your own unit leak most? Most offices say Share. BRING IT HOME: the process map some teams made this morning follows these same six stages.



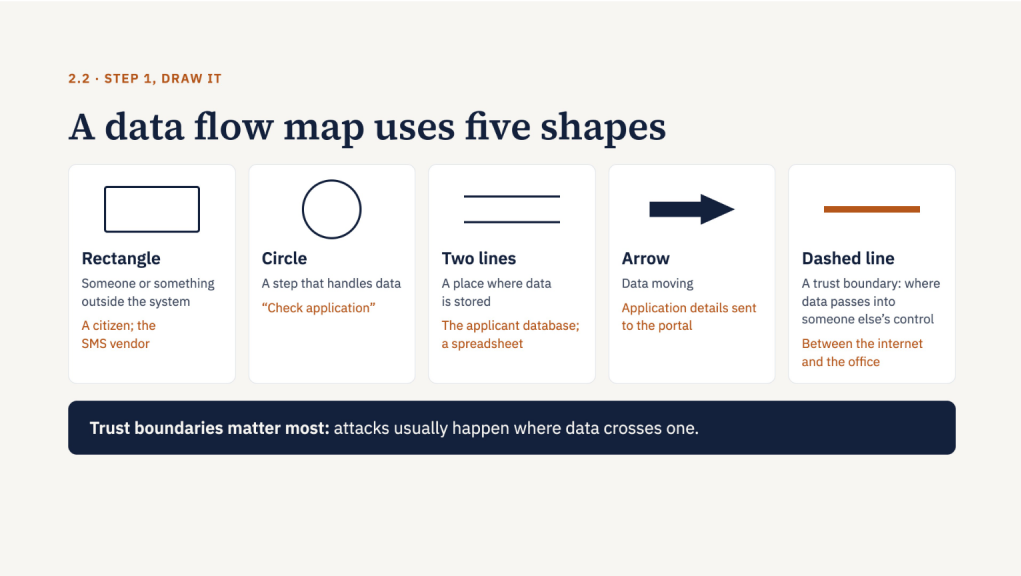

TIME: 10 minutes (6 in teams, 4 debrief). Face-to-face: teams fill the Try it 2.1 table in the learner guide. Online: give each breakout room two situations, then debrief in the main room. MODEL ANSWERS (accept others with a sound reason): 1. Admin page open to the internet with a default password; technology; every applicant record; close the admin page to the internet, change the password and add MFA. 2. Shared login; people and process; the approval spreadsheet and payouts; one account per person, with logs. 3. Access not removed when a contractor left; process; everything the VPN reaches; disable accounts on the last day and review accounts monthly. 4. Backups never test-restored; process; all data, if ransomware strikes; test a restore regularly and keep an offline copy. 5. Applicant forms on personal USB sticks; technology and process; sensitive applicant data; office-issued encrypted USB sticks, with the head's approval and at most 1,000 records at a time (DPA Section 23). 6. Operating system out of support; technology; the server and everything on it; plan the upgrade, and meanwhile isolate the server and record the risk in the register. DEBRIEF: Ask a team with mostly non-IT members to answer situations 2, 3 and 4 first. These are process weaknesses that managers and staff can fix without new technology. LINK: Several of these six return in the graded risk assessment, so teams should keep their answers.




TIME: 2 minutes. Ask each question to the whole room and wait for answers before confirming. Do not show the answers on screen. ANSWERS: 1. The window left unlocked. 2. People, process and technology. 3. Exploiting vulnerabilities, at 31% of breaches, ahead of stolen credentials at 13%. 4. CVSS measures technical severity, not what the weakness would cost your office. A Medium weakness on the system that holds 48,000 records may matter more than a High one on a test machine. TIP: The same four questions are in the learner guide. Anyone who missed one should mark it to review before Quiz 2.

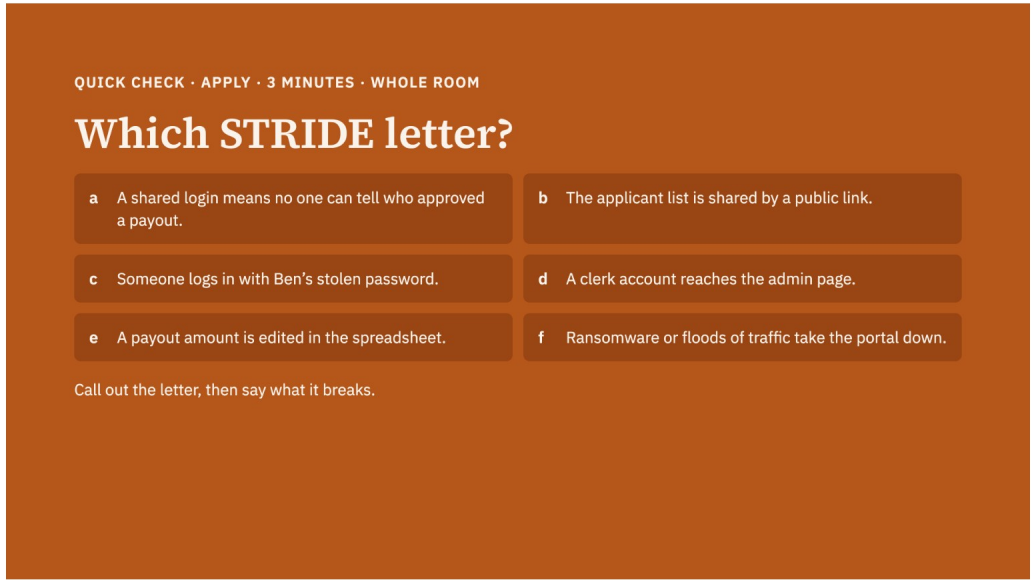



TIME: 3 minutes. SAY: Threat modeling sounds technical, but it rests on four plain questions, set out in the Threat Modeling Manifesto by a group of practitioners. What are we working on? We draw the process. What can go wrong? We go through a checklist, step by step, and look at how attackers move. What are we going to do about it? We rate the risks and choose a treatment for each. Did we do a good enough job? We check the result with the people who actually run the process. KEY POINT: Anyone who knows a process can do this. Ben knows the approval spreadsheet better than any outside expert, and Dan knows exactly how payouts reach the e-wallet provider. Knowing the work is what makes a threat model accurate. ASK: When did your office last ask "what can go wrong?" before launching a new online form or service? LINK: The next slides are the four steps, in order. Your team uses the same steps at 3:50.

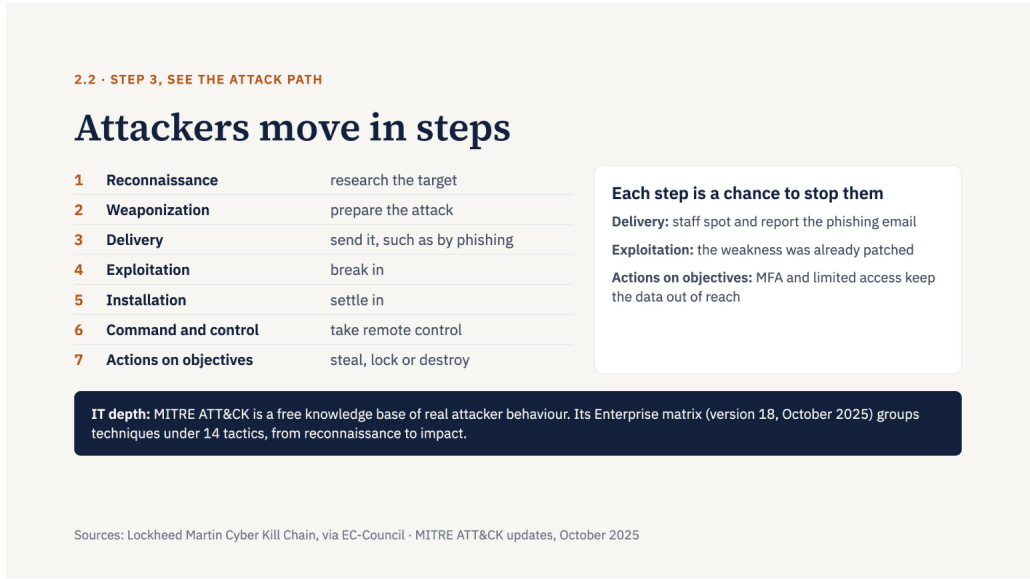



TIME: 4 minutes. SAY: Step 1 answers "what are we working on?" by drawing it, and five shapes are enough. A rectangle is someone or something outside the system that sends or receives data: a citizen, or the SMS vendor. A circle is a step that handles data, named with a verb, such as "Check application". Two parallel lines are a place where data is stored: the applicant database, or a spreadsheet. An arrow is data moving, labelled with what moves. A dashed line is a trust boundary, where data passes into someone else's control: between the internet and the office, or between the office and a vendor. KEY POINT: Read the dark box aloud. Attacks usually happen where data crosses a trust boundary, so that is where we look hardest. ASK: In the RSSO portal, where does data leave the office's control? (To the SMS vendor, to the e-wallet provider, and to staff phones and home connections.) TIP: Neatness does not matter. A complete map drawn by hand beats a beautiful one that misses a vendor. PLAIN WORDS: specialists call this a data flow diagram, or DFD.

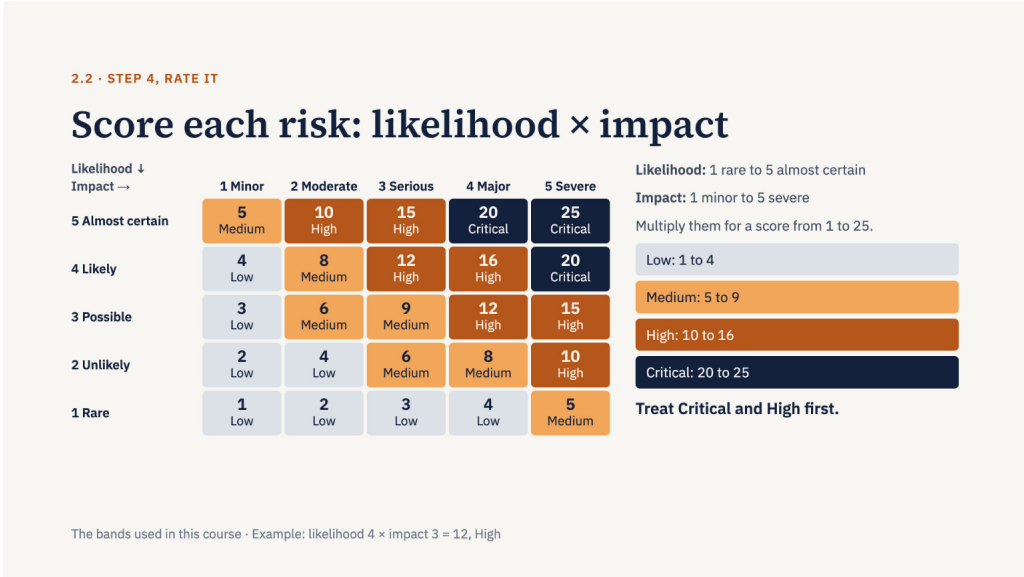
TIME: 5 minutes. SAY: Step 2 answers "what can go wrong?". STRIDE is a checklist of six kinds of threats, developed at Microsoft. Each letter is a question to ask at every step and every trust boundary on your map. S, spoofing: pretending to be someone else, for example logging in with Ben's stolen password; it breaks authentication, the proof of who you are. T, tampering: changing data without permission, such as editing a payout amount; it breaks integrity, this morning's Correct. R, repudiation: denying you did something when there is no record to prove it; with a shared login, no one can tell who approved a payout. I, information disclosure: data seen by the wrong people, such as the applicant list shared by a public link; it breaks Secret. D, denial of service: making the system unavailable, through ransomware or floods of traffic; it breaks Ready. E, elevation of privilege: getting powers you should not have, such as a clerk account that reaches the admin page; it breaks authorization. MEMORY HOOK: three letters are this morning's Secret, Correct, Ready: I, T and D. The other three are about identity: who you are (S), what you did (R), and what you may do (E). ASK: Which STRIDE threats does a shared password make easier? (Spoofing and repudiation.)




TIME: 3 minutes. Read each situation and let the room call out the letter before you confirm. Online: answers in the chat, then confirm. ANSWERS: a. R, repudiation: there is no record of who did what, so non-repudiation is broken. b. I, information disclosure: breaks Secret. c. S, spoofing: breaks authentication. d. E, elevation of privilege: breaks authorization. e. T, tampering: breaks Correct. f. D, denial of service: breaks Ready. WATCH FOR: confusion between S and E. Spoofing is pretending to be someone else; elevation is getting more power than your own account should have. IF TIME ALLOWS: ask which single change helps with a, c and d together. (One named account per person, protected with MFA, with only the access each role needs.)

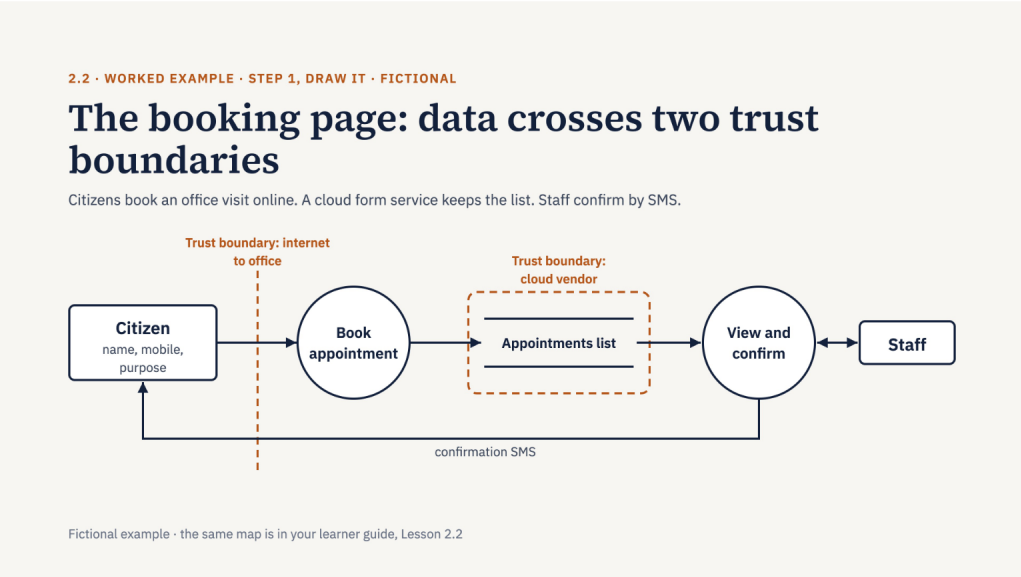



TIME: 4 minutes. SAY: Step 3 looks at how attackers move. Lockheed Martin's Cyber Kill Chain names seven steps. Reconnaissance: they research the target, for example staff names and email addresses on the office website. Weaponization: they prepare the attack, such as a fake invoice carrying a harmful file. Delivery: they send it, often by phishing. Exploitation: they break in, through a click or an unpatched weakness. Installation: they settle in so they can come back. Command and control: they take remote control. Actions on objectives: they steal, lock or destroy. KEY POINT: Each step is a chance to spot and stop them. A clerk who reports a phishing email stops the attack at delivery; a patch already applied stops it at exploitation; MFA and limited access keep the data out of reach even if attackers get in. ASK: At which step can a non-IT employee stop an attack? (Delivery, by spotting and reporting; and reconnaissance, by sharing less about the office online.) IT DEPTH: MITRE ATT&CK is a free knowledge base of real attacker techniques. Its Enterprise matrix, version 18 from October 2025, groups them under 14 tactics, from reconnaissance to impact. IT staff can use it to check what their monitoring would detect. IF RUNNING LATE: skip the IT depth box.




TIME: 6 minutes. SAY: Now we rate. Give each threat a likelihood from 1, rare, to 5, almost certain, and an impact from 1, minor, to 5, severe. Multiply them, and the score runs from 1 to 25. This course uses four bands: Low 1 to 4, Medium 5 to 9, High 10 to 16, Critical 20 to 25. Treat Critical and High first. WORKED EXAMPLE: the RSSO admin page open to the internet with a default password. Likelihood? Attackers search for exposed pages all the time, so 4, likely. Impact? The sensitive data of 48,000 people, so 5, severe. Score 20, Critical: point to the cell. Now a visitor logbook with names only, left on the front desk: likelihood 2, impact 2, score 4, Low. ASK: A risk has likelihood 2 and impact 5. Score and band? (10, High: even an unlikely event is High when the harm is severe.) WATCH FOR: teams that rate everything 5. Ask for a one-line reason for each rating; consistency matters more than precision, and the rubric rewards justified ratings. PLAIN WORDS: these numbers are careful judgements, not measurements. Two careful teams may differ by one point, and that is fine. NOTE: scores of 17 to 19 cannot occur, because no two numbers from 1 to 5 multiply to them.

TIME: 5 minutes. SAY: Still Step 4: what are we going to do about each risk? There are four choices; remember TARA. Transfer: pass part of the consequence to someone else, for example insurance, or a vendor contract that gives the vendor security duties. Avoid: stop the activity that creates the risk, for example stop collecting a field you never use. Reduce: add a control that lowers the likelihood or the impact, such as MFA, encryption or training; this is the most common choice. Accept: keep the risk, with written approval, when it is Low and would cost more to fix than it could ever lose. CAUTION: Transfer moves some of the cost, never the accountability. Under the DPA, the office stays responsible for personal data that its vendors process for it (Sections 14 and 21). REGISTER: read the dark box. Every risk gets an owner, a named person rather than a unit, so someone answers for it. The risk left after treatment is the score you expect once the control is in place. ISO 27001 asks risk owners to approve the treatment plan and to accept the risk that is left (clause 6.1.3). ASK: The RSSO buys cyber insurance. Which treatment is that, and is the office still accountable? (Transfer; yes, it is.) PLAIN WORDS: ISO/IEC 27005, the risk management guide in the ISO 27000 family, calls these sharing, avoidance, modification and retention.




TIME: 7 minutes. CO-BUILD FIRST: before showing this slide, draw the map live with the room, on the whiteboard face-to-face or on the shared canvas online, using the same template teams will use at 3:50. Then reveal this slide as the clean version. QUESTION 1, WHAT ARE WE WORKING ON: the RSSO's online appointment booking page. Citizens give their name, mobile number and purpose; a cloud form service keeps the list; staff check it and send a confirmation by SMS. DRAW, asking the room at each step: the citizen, a rectangle, outside the system; "Book appointment", a circle; the appointments list, two lines, kept by the vendor; "View and confirm", a circle; staff, a rectangle; an arrow for each flow, including the confirmation SMS going back to the citizen. BOUNDARIES: ask "where does the data pass into someone else's control?" Mark the dashed line between the internet and the office, and the dashed box around the vendor's cloud service. KEY POINT: the citizen's data crosses two trust boundaries, from the internet into the office and then into a vendor's cloud. Those crossings are where attacks are most likely, so Step 2 looks there first. ASK: What data crosses each boundary? (Name, mobile number and purpose going in; the SMS confirmation going out.) WATCH FOR: maps that forget return flows such as the SMS. Data going out to people crosses boundaries too. IF RUNNING LATE: skip the live drawing and walk through this slide instead; the whole worked example can shrink to 8 minutes.

2.2 · WORKED EXAMPLE · STEP 2 AT EACH ELEMENT

## Three things that could go wrong

| Element | STRIDE | Threat | Control |
|---|---|---|---|
| Book appointment | Spoofing | Someone books in another person's name and number | A one-time code sent to the mobile number |
| Appointments list | Information disclosure | The list is shared by a public link | Access only for named staff accounts |
| Book appointment | Denial of service | Automated fake bookings fill every slot | Limit bookings per number; a human check |

Ask all six STRIDE letters at each element, then keep the threats that matter.

Fictional example · learner guide, Lesson 2.2, worked example

TIME: 4 minutes. SAY: Step 2: walk STRIDE along the map, starting where data crosses a boundary. Three threats are enough to show the method. Spoofing at "Book appointment": someone books in another person's name and number; a one-time code sent to that mobile number proves the person controls it. Information disclosure at the appointments list: the list is shared by a public link, so anyone with the link can see who is visiting and why; the control is access for named staff accounts only. Denial of service at "Book appointment": automated fake bookings fill every slot, so real citizens cannot book; limit bookings per number and add a human check. ASK: What other threats can the room find? Take two. Likely answers: tampering, someone changes bookings in the list; repudiation, a shared vendor login hides who deleted a booking; elevation of privilege, a staff account with admin rights on the form service it does not need; information disclosure, an SMS that reveals the purpose of the visit, such as a medical concern, to anyone who sees the phone. TIP: the "Who is harmed" column in the team threat table keeps attention on citizens, not only on systems.

2.2 · WORKED EXAMPLE · STEP 4 IN THE RISK REGISTER

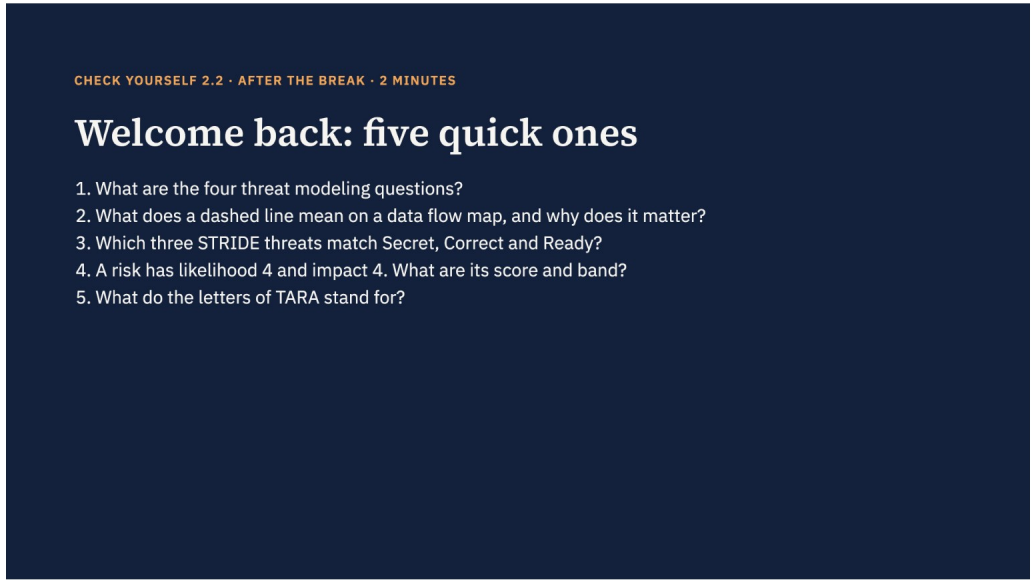
## Two risks, rated and treated

| Risk | Owner | Likelihood | Impact | Score | Treatment |
|---|---|---|---|---|---|
| Appointments list exposed by a public link | Ana (IT officer) | 4 | 3 | 12 High | Reduce: remove public links, named accounts only |
| Fake bookings fill the calendar | Ben (records clerk) | 3 | 2 | 6 Medium | Reduce: booking limit per number; review daily |

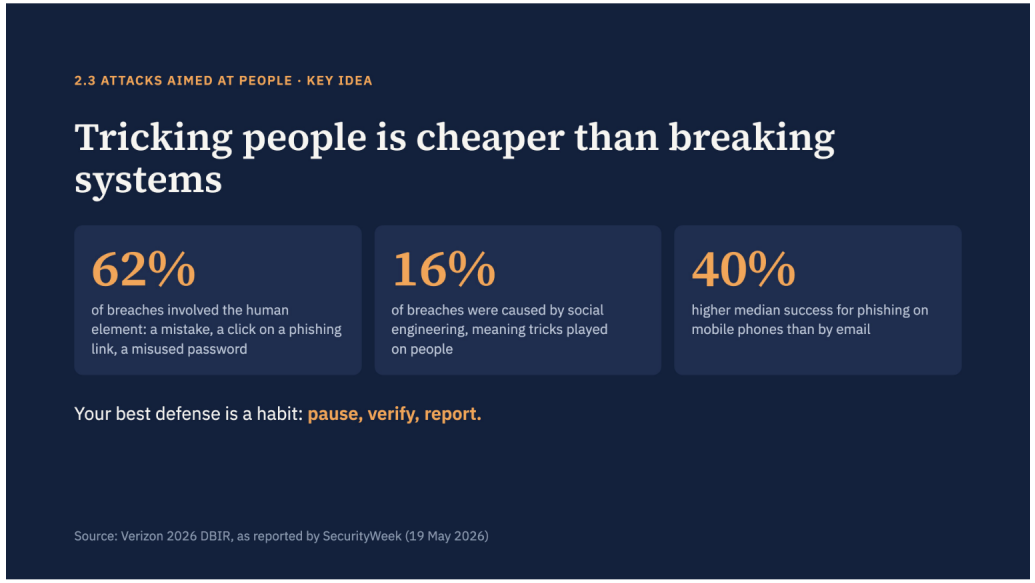
Every risk has a named owner, and High comes before Medium.

Fictional example · learner guide, Lesson 2.2 · Scores use the course's 5 by 5 bands

TIME: 4 minutes. SAY: Step 4: rate, treat and record. The public link: likelihood 4, because public links are easy to forward and hard to control once shared; impact 3, because the list holds names, mobile numbers and visit purposes, which can reveal private matters, but no ID numbers or health records. Score 12, High. Owner: Ana, the IT officer, because she manages the form service settings. Treatment: Reduce, by removing public links and allowing named staff accounts only. Fake bookings: likelihood 3, possible; impact 2, moderate, because citizens are delayed and staff time is lost, but no data is exposed. Score 6, Medium. Owner: Ben, who runs the bookings. Treatment: Reduce, with a booking limit per number and a daily review. ASK: After Ana removes the public links, what risk is left? (For example, likelihood 2 times impact 3 gives 6, Medium. That goes in the register as the risk left after treatment.) KEY POINT: every rating needs a one-line reason. That is exactly what the rubric checks at 3:50. LINK: The team template in the learner guide has these same columns, plus a column for the control and the reason.

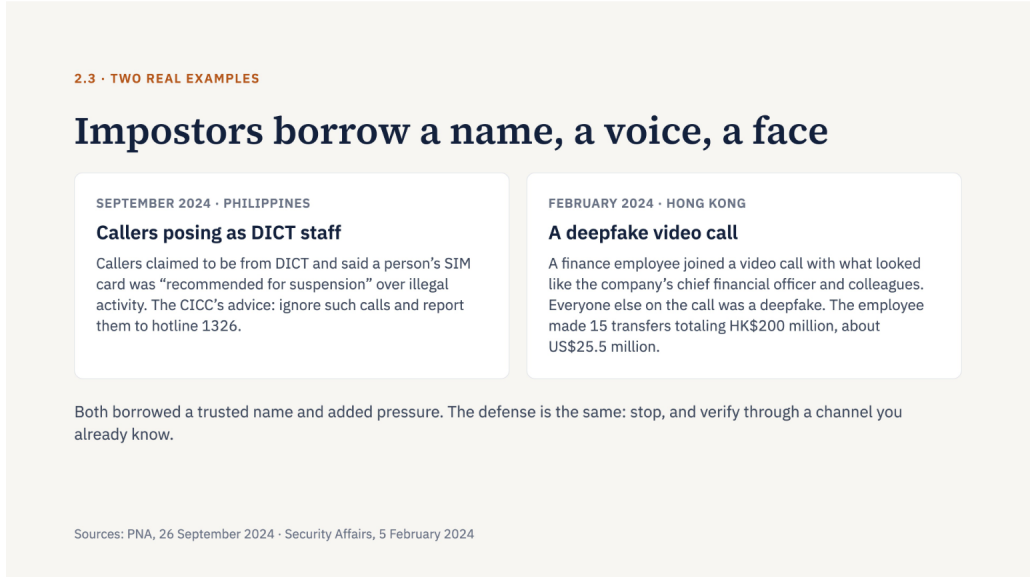



TIME: 2 minutes. Recalling after a break is what makes 2.2 stick, so ask before anyone opens the guide. Take answers from different teams. ANSWERS: 1. What are we working on? What can go wrong? What are we going to do about it? Did we do a good enough job? 2. A trust boundary, where data passes into someone else's control. Attacks usually happen where data crosses one. 3. Information disclosure (Secret), tampering (Correct) and denial of service (Ready). 4. 16, High. 5. Transfer, Avoid, Reduce, Accept. LINK: Now 2.3, the attacks aimed at people. They cross trust boundaries too: a phishing email is data crossing from the internet into your inbox.



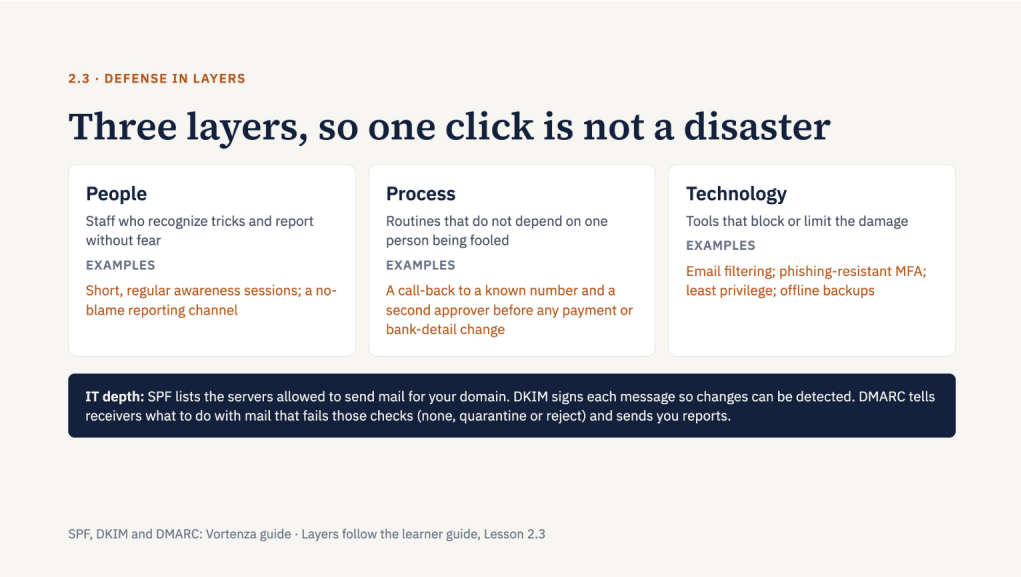

TIME: 3 minutes. SAY: Attackers trick people because it is cheaper and faster than breaking systems: one convincing message can open every door that the person's account can open. In Verizon's 2026 report, 62 percent of breaches involved the human element, meaning a person's mistake, a click on a phishing link, or a misused password. 16 percent of breaches were caused by social engineering, which means tricks played on people. And phishing on mobile phones succeeded more often than phishing by email, with a median success rate 40 percent higher. Think about why: a small screen hides the real sender and the real link, and we read messages on the move. KEY POINT: This is not about blaming people. It means people are part of the defense, and a habit beats a warning: pause, verify, report. ASK: How many of you read work messages on your phone? (Most.) So the phone is where this afternoon's skills matter most.

TIME: 6 minutes. SAY: Knowing the names helps people recognize and report these tricks. Go row by row and ask for an example of each from the room, without names. Phishing, spear phishing, whaling and smishing: the same trick by email or text, from mass messages to ones written for one person or for a head of office. Vishing: phone calls, often from a caller posing as an agency, a bank or the police. Quishing: a QR code, for example on a poster, that leads to a fake page. Business email compromise: a fake or hijacked supplier or official account asks to change bank details or to pay an urgent invoice. Pretexting: a made-up story to get information, such as "I'm from IT and need your one-time code". MFA fatigue: repeated sign-in prompts until someone taps Approve just to make them stop; if you get a prompt you did not start, deny it and report it. Tailgating: following someone through a secured door. USB baiting: a "lost" USB stick left for someone to plug in. Deepfakes: AI-made voice or video of a real person, which links back to this morning's generative AI risks. KEY POINT (footer): ransomware usually starts the same way, with a phishing message or a stolen password; then attackers spread inside, steal data and lock files. ASK: Which of these has someone in your office received this year? Smishing and vishing are the usual answers.

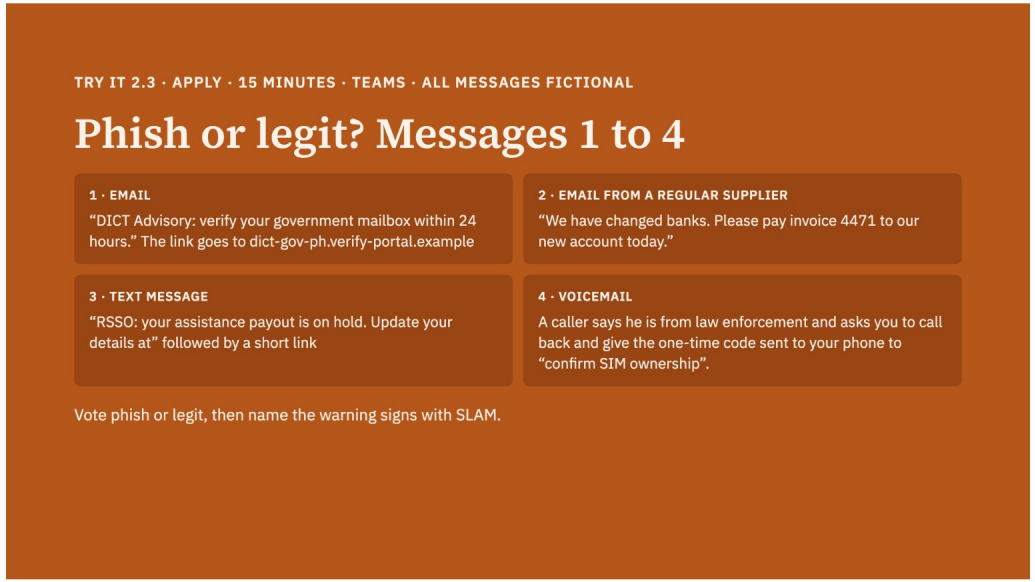



TIME: 3 minutes. SAY: Two real cases, one at home and one abroad. First: in September 2024, the CICC warned of callers claiming to be from DICT who told people their SIM card was "recommended for suspension" over illegal activity. The fear of losing your number is the pressure. The CICC's advice was to ignore such calls and report them to hotline 1326. Second: in February 2024, a finance employee at a multinational company's Hong Kong office joined a video call with what looked like the company's chief financial officer and several colleagues. Everyone else on the call was a deepfake. The employee made 15 transfers totaling 200 million Hong Kong dollars, about 25.5 million US dollars. KEY POINT: Both borrowed a trusted name and added pressure. Seeing a face or hearing a voice is no longer proof of who someone is. The defense is the same as for any message: stop, and verify through a channel you already know, such as calling back on a number from your own records. ASK: At the RSSO, what would stop a deepfake "Director Eva" from ordering an urgent payout? (A call-back to a known number, and a second approver.) LINK: This morning's ASEAN guide listed deepfakes and fraud among the generative AI risks.

TIME: 4 minutes. SAY: SLAM is a four-step check for any message, on any device. S, Sender: a name you know but an odd address; a free email account sending an "official" message; an agency domain spelled slightly wrong. Philippine government offices normally use addresses ending in .gov.ph. L, Links: on a computer, hover over the link; on a phone, press and hold it, and read the real address before you tap. Be wary of short links, and of login pages reached from a message. A, Attachments: files you did not expect, especially compressed archives, documents that ask you to "enable content", and surprise "invoices". M, Message: urgency, threats, rewards and secrecy, or any request for passwords, one-time codes, payments or changes to bank details. THEN: pause, verify, report. Verify through a number or address you already know, never the one in the message, because the scammer controls anything in the message. Never share a one-time code with anyone; no genuine agency, bank or IT unit needs it. ASK: Which SLAM letter would have caught the deepfake call? (M: an urgent, secret request for transfers. Then verify by calling back.) PRACTICE: the next activity uses SLAM on eight messages.

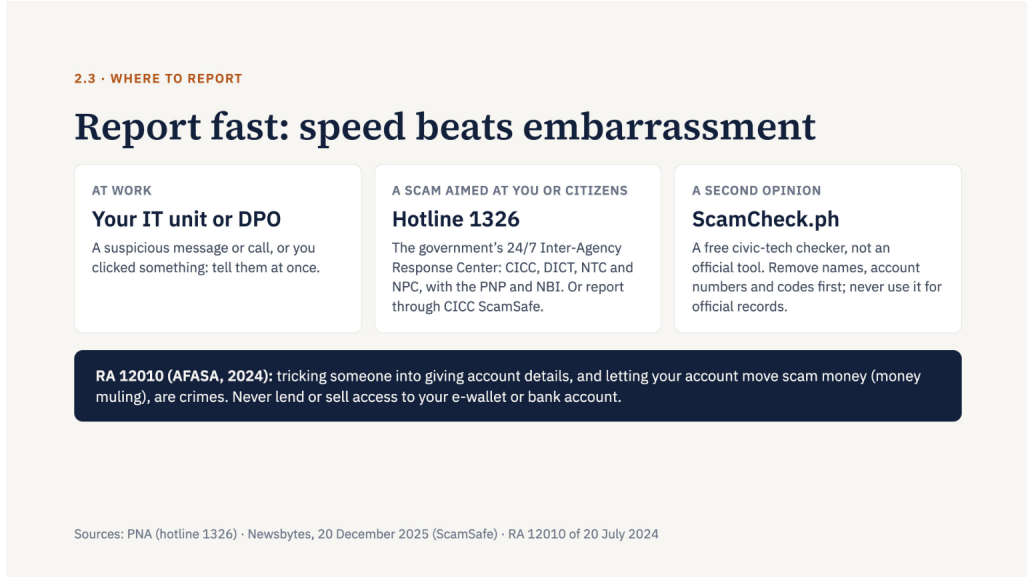



TIME: 4 minutes. SAY: No single defense is enough, so we build three layers, the same People, Process and Technology we used to find weaknesses. People: staff who recognize tricks and report them without fear of blame. The no-blame part matters: the person who reports a click within minutes protects the office; the one who hides it out of embarrassment lets the attack spread. Process: routines that do not depend on one person being fooled. Before any payment or bank-detail change, a call-back to a number already on file and a second approver. A call-back to the real person on a known number is exactly what defeats a fake bank-detail request or a deepfake order. Technology: email filtering; phishing-resistant MFA, such as passkeys or security keys, which a fake login page cannot capture and reuse; least privilege, so each account reaches only what its job needs; and offline backups that ransomware cannot reach. IT DEPTH: three email records help receivers spot forged mail that claims to come from your domain: SPF, DKIM and DMARC. Ask IT staff to check that their domain has all three, and that the DMARC policy moves from none toward quarantine or reject. ASK: Which layer could Dan, the cashier, add tomorrow without buying anything? (The call-back and second-approver routine.) IF RUNNING LATE: skip the IT depth box.

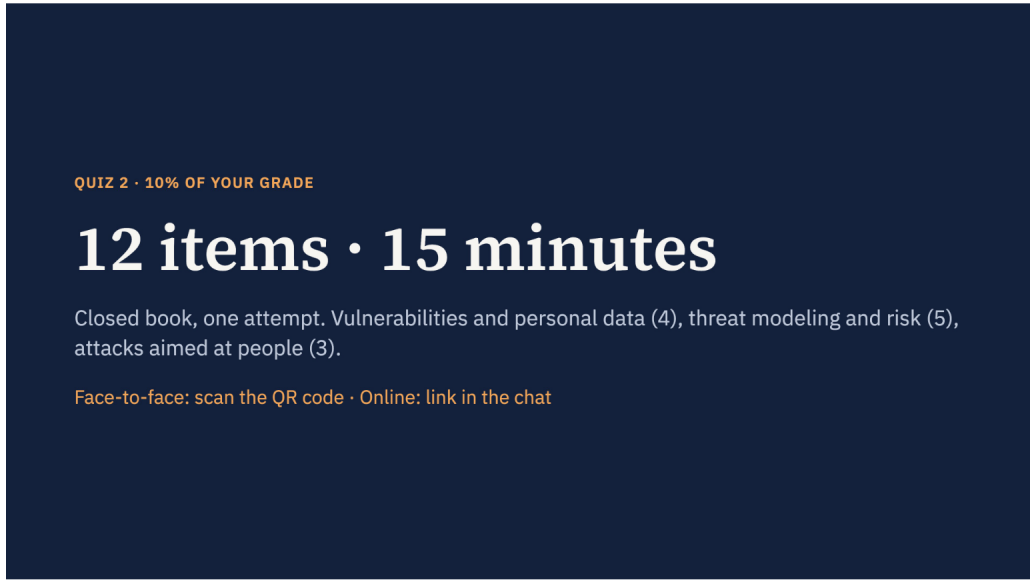



TIME: 7 minutes for messages 1 to 4 (4 in teams, 3 for the debrief). ALL FICTIONAL: say so clearly. The web address in message 1 ends in .example, a name reserved for examples, so it can never be a real site. Face-to-face: teams vote with a show of hands or cards, then name the warning signs. Online: one poll per message, then reasons in the chat. ANSWERS: 1. Phish. A look-alike address that is not a .gov.ph domain, a 24-hour deadline, and a login link. 2. Phish until verified: business email compromise. A bank-detail change plus urgency. Call the supplier on the number in your own files, and get a second approval. 3. Phish: smishing. A short link, pressure about a payout, and a request to update details by text. 4. Phish: vishing. Authority plus a request for a one-time code. Never share a one-time code; report the call to 1326. WATCH FOR: teams that call message 2 legit because the supplier is real. A real supplier's email account can be hijacked; the request itself is the warning sign.

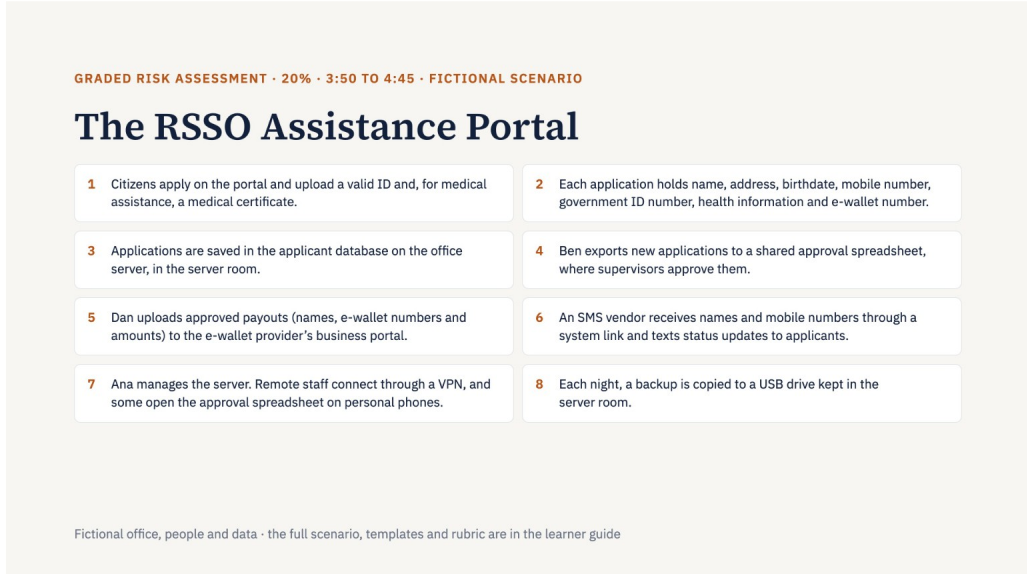
TIME: 8 minutes for messages 5 to 8 (4 in teams, 4 for the debrief and the experiment). ANSWERS: 5. Phish: quishing. A QR code on an unofficial poster leading to a claim page. Check the office's official channels instead. 6. Phish from a hijacked account: urgency, an unusual tone, and a link to a password page. Call your colleague to check, and report it. 7. Legit: a known sender, no link or attachment, and it matches the memo. 8. Legit: no link, and it tells you to call a number you already have, the one on your card. KEY POINT: the two genuine messages show what safe looks like: nothing to click, and a way to verify that you already control. EXPERIMENT (4 minutes, if the internet works): open ScamCheck.ph on the projector and paste messages 3 and 6, which are fictional. Before pressing check, ask the room to predict the verdict; then compare. SAY: ScamCheck.ph is a free AI-assisted checker built by the civic-tech group BetterGov.PH. It is not an official government tool, and AI results can be wrong, so your SLAM check and verification still decide. Never paste real names, account numbers, one-time codes or official records into any public checker. FALLBACK: with no connection, skip the experiment and use the time for the debrief.



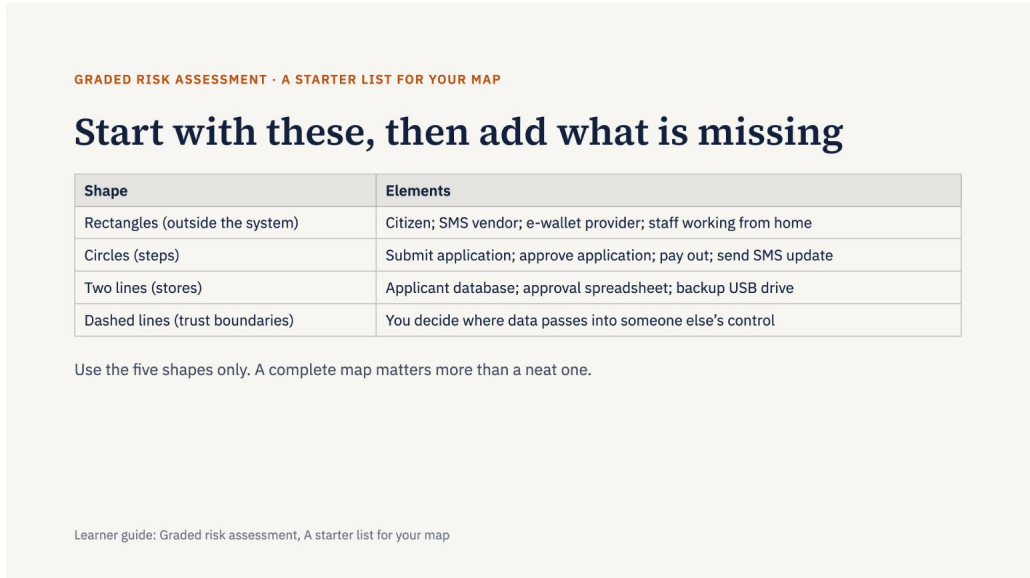

TIME: 3 minutes. SAY: Reporting fast matters more than anything else on this slide. At work: if a message or call looks wrong, or you already clicked, tell your IT unit or DPO at once. Minutes count, and no one should be blamed for reporting. This links to this morning's 72-hour clock: the office cannot notify on time about something it never hears. For scams aimed at you or at citizens: hotline 1326, the government's 24/7 Inter-Agency Response Center, run by the CICC, DICT, NTC and NPC, with the PNP and NBI as its law enforcement arm. Or CICC ScamSafe, the reporting and information platform launched on 19 December 2025. For a second opinion on a message: ScamCheck.ph, a free civic-tech checker; it is not an official government tool, so strip out personal details first. THE LAW: under the Anti-Financial Account Scamming Act, RA 12010 of 20 July 2024, social engineering schemes that trick people into giving account details, and money muling, letting your account be used to move scam money, are crimes. Tell citizens and family members: never lend or sell access to your e-wallet or bank account. ASK: Who has saved 1326 in their phone? Ask everyone to save it now, before the break.




TIME: 15 minutes. BEFORE THE SESSION: add the QR code and short link for this run's Quiz 2 form to this slide; the online run uses its own form, so its answers stay separate. Keep printed copies and answer sheets as backup. DURING: start a 15-minute countdown on the main screen. Face-to-face, walk the room; online, keep cameras on where bandwidth allows. FORM SETTINGS: quiz mode, one point per item, shuffled questions and options, one response per person, and scores released only after the review. Collect name and office only. CONTENT: 12 items, ten multiple choice (four of them short scenarios) and two true or false, all drawn from the Check yourself questions and the desk card. AFTER: there is no review slot here, because the risk assessment starts at 3:50. Review the two or three most-missed items in the 4:45 close, then release the scores. The answer key is in the facilitator-only Quiz Bank.




TIME: 2 minutes. SAY: This is the system your team will assess. Read it as a story, following the data. Citizens apply online with an ID and, for medical assistance, a medical certificate, so each application holds sensitive data. It lands in the applicant database on the office server. Ben exports new applications to a shared approval spreadsheet. Dan uploads approved payouts to the e-wallet provider's business portal. An SMS vendor receives names and mobile numbers through a system link. Ana manages the server; remote staff use a VPN, and some open the approval spreadsheet on personal phones. Each night a backup goes to a USB drive in the server room. ASK: How many places does the data leave the office's control? (At least four: the SMS vendor, the e-wallet provider, personal phones, and remote connections.) And which copy of the data is easiest to walk away with? (The backup USB drive.) KEY POINT: everything here is fictional. Teams should not add details from their own office's real systems.



GRADED RISK ASSESSMENT · A STARTER LIST FOR YOUR MAP

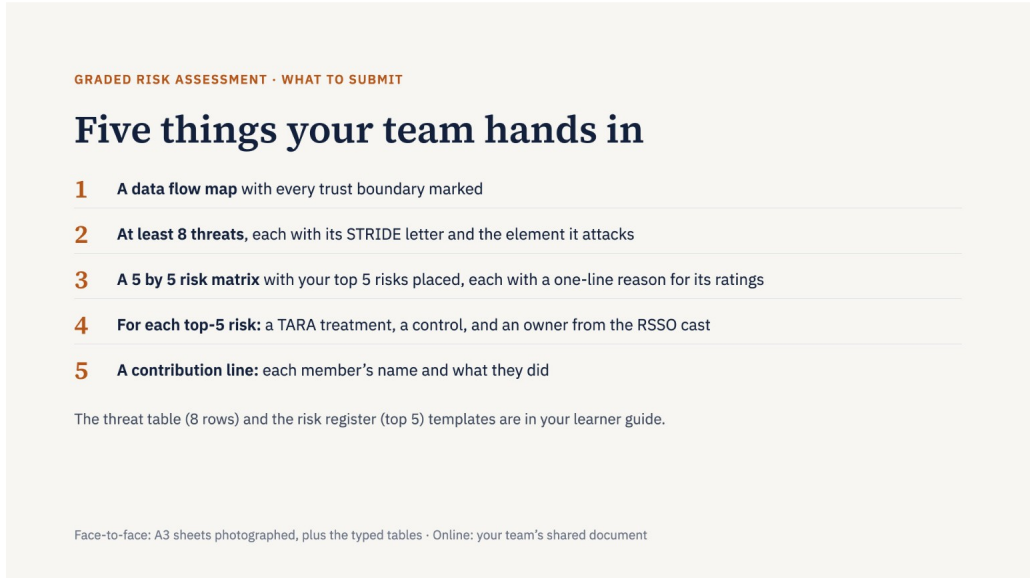
## Start with these, then add what is missing

| Shape | Elements |
|---|---|
| Rectangles (outside the system) | Citizen; SMS vendor; e-wallet provider; staff working from home |
| Circles (steps) | Submit application; approve application; pay out; send SMS update |
| Two lines (stores) | Applicant database; approval spreadsheet; backup USB drive |
| Dashed lines (trust boundaries) | You decide where data passes into someone else's control |

Use the five shapes only. A complete map matters more than a neat one.

Learner guide: Graded risk assessment, A starter list for your map

TIME: 1 minute. SAY: To save time, here is a starter list for your map. Four rectangles: the citizen, the SMS vendor, the e-wallet provider, and staff working from home. Four steps: submit, approve, pay out, and send SMS update. Three stores: the applicant database, the approval spreadsheet, and the backup USB drive. The trust boundaries are for your team to decide: where does data pass into someone else's control? Add anything you think is missing, such as personal phones. TIP: a complete map drawn by hand beats a neat one that misses a vendor.




TIME: 1 minute. SAY: Five things. A data flow map with every trust boundary marked. At least eight threats, each with its STRIDE letter and the element it attacks. A 5 by 5 risk matrix with your top five risks placed, each with a one-line reason for its ratings. For each top-five risk: a TARA treatment, a control, and an owner from the RSSO cast. And a contribution line with each member's name and what they did. FORMAT: face-to-face, photograph your A3 sheets and add the typed tables; online, work in your team's shared document. One file per team. TIP: the templates in the learner guide already have the right columns, so teams do not need to design their own.

GRADED RISK ASSESSMENT · HOW IT IS SCORED

## 100 points, scaled to 20% of your grade

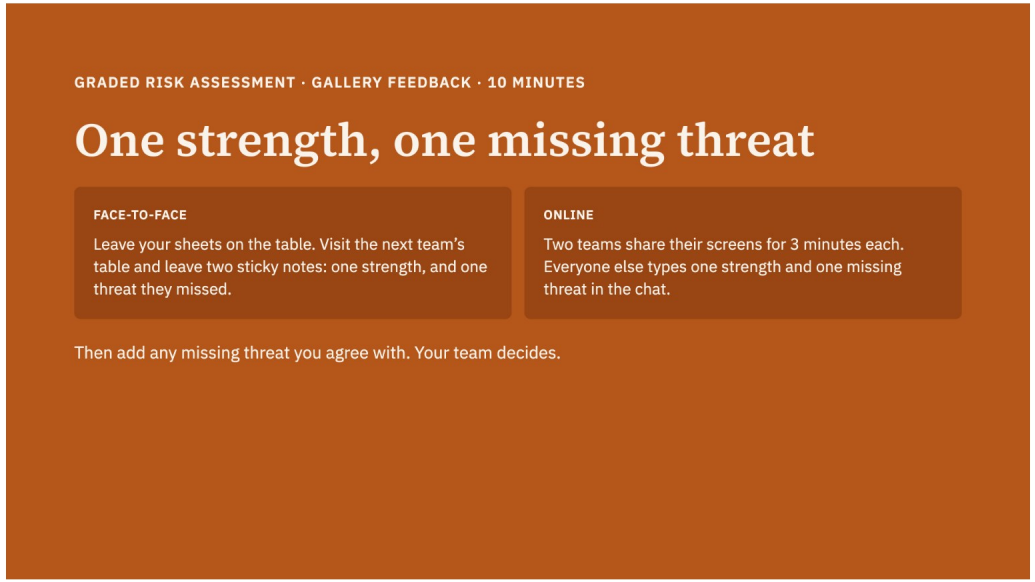
| Criterion | Points | Full marks means |
|---|---|---|
| Scope and scenario understanding | 15 | Assets, data and the system boundary are stated correctly |
| Threat model | 35 | A data flow map with trust boundaries; at least 8 threats mapped to STRIDE and to the element they attack |
| Risk matrix | 30 | Likelihood and impact rated consistently and justified; the top 5 risks prioritized |
| Treatment | 20 | Each top risk has a relevant control, an owner and a TARA treatment |

Every member receives the team score.

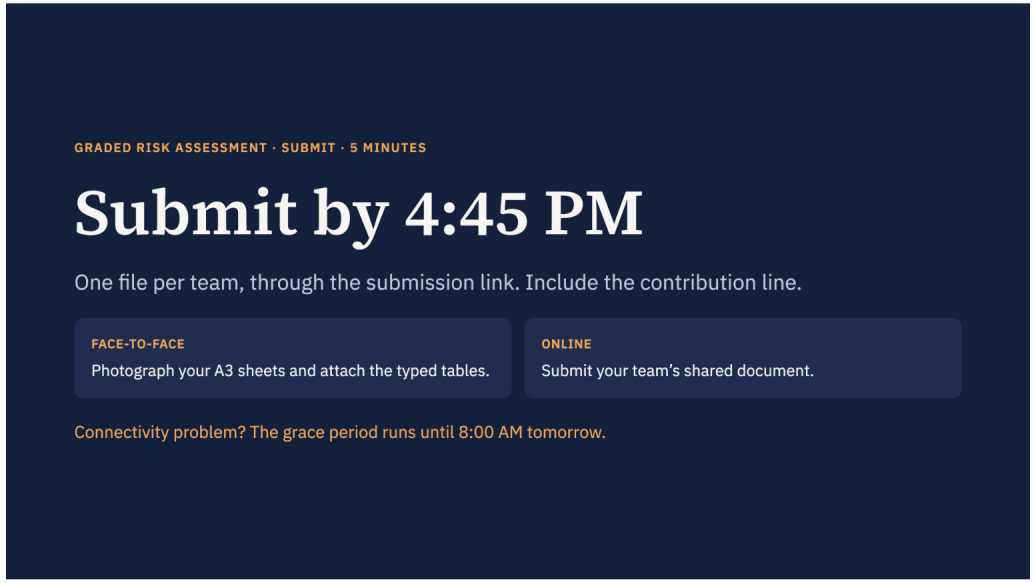
Scored after the session by the facilitators · the same rubric is in your learner guide

TIME: 1 minute. SAY: The rubric, so nothing is a surprise. Scope, 15 points: state correctly what the assets, the data and the system boundary are. Threat model, 35 points, the biggest share: a map with trust boundaries, and at least eight threats tied to STRIDE and to the element they attack. Risk matrix, 30 points: ratings that are consistent and justified, with the top five prioritized. Treatment, 20 points: each top risk has a relevant control, an owner and a TARA treatment. Everyone on the team receives the team score. The contribution line is used only for exceptions, and any exception is flagged to ILCDB rather than decided here. TIP: a one-line reason beside each rating is the cheapest way to earn the matrix points.

TIME: 35 minutes (3:55 to 4:30). START: confirm every team has the scenario, the starter list and the templates, then leave this slide up for the whole build. CHECKPOINTS: call out each time on the slide; a team that is behind should move on and come back later. FACE-TO-FACE: A3 canvases for the map and the matrix, sticky notes for threats, and one laptop per team to type the tables. Circulate, spending no more than 3 minutes per table. ONLINE: one pre-built shared document per team in its breakout room; you and the co-host visit each room about every 10 minutes. COACHING QUESTIONS (ask, do not answer): Where does data leave the office's control? What happens if someone changes the approval spreadsheet? Who could deny approving a payout? What if the backup drive is stolen, or the vendor link is abused? What does a lost personal phone expose? MIXED TEAMS: non-IT members often see the process weaknesses first, in approvals, exports, payouts and backups; IT members help name them with STRIDE. EXPECT TO SEE (for scoring; do not hand out): spoofing of staff logins over the VPN; tampering with the approval spreadsheet or the payout file; repudiation through shared logins; disclosure through the SMS link, personal phones or a lost backup drive; denial of service by ransomware reaching the server and the backup; elevation of privilege through a clerk account with admin rights. IF RUNNING LATE: keep the full build time and shorten the gallery to two teams instead.

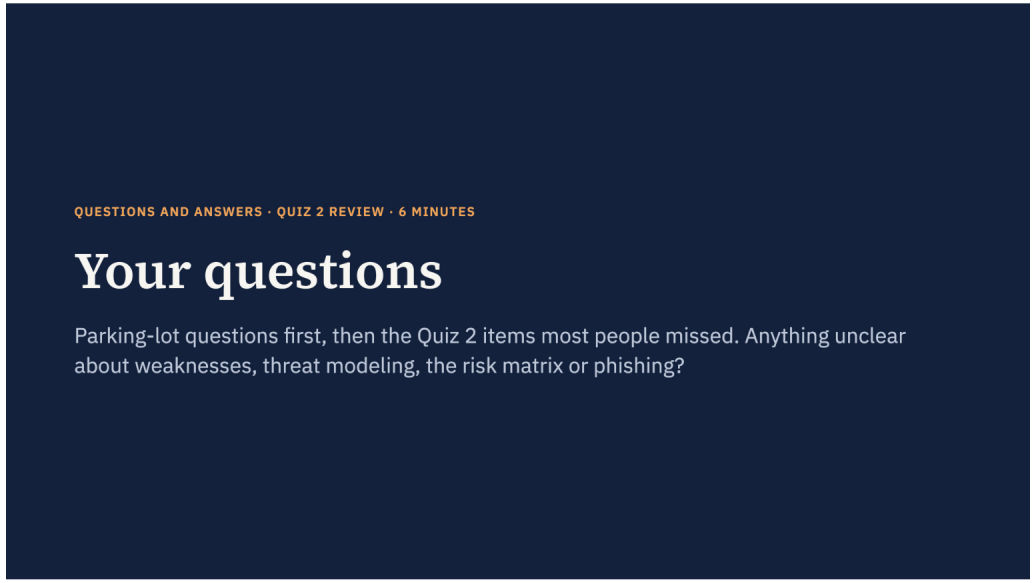



TIME: 10 minutes (4:30 to 4:40). PURPOSE: feedback before submission, so teams can improve their own work. The gallery itself is not scored. FACE-TO-FACE: teams leave their sheets on the table and rotate clockwise to the next table for 5 minutes. Each visiting team leaves two sticky notes: one strength, and one threat the other team missed. Everyone then returns for 3 minutes to read the notes and decide what to add. ONLINE: two teams share their screens for 3 minutes each while everyone else types one strength and one missing threat in the chat; then all teams take 2 minutes in their rooms to update. SAY: Accept or ignore the feedback; your team decides. WATCH FOR: copying. Adding a threat you agree with is fine; copying another team's matrix is not. IF RUNNING LATE: two teams only, then straight to submission.




TIME: 5 minutes (4:40 to 4:45). BEFORE THE SESSION: put this run's submission link on this slide and in the chat; keep the face-to-face and online submissions in separate folders. SAY: One file per team through the submission link, by 4:45. Face-to-face: photograph your A3 sheets clearly, in good light, and attach the typed tables. Online: submit your team's shared document. Include the contribution line. GRACE PERIOD: if connectivity fails, the grace period runs until 8:00 AM tomorrow. It is for connection problems only, not for extra work. CHECK: before moving on, confirm on your list that every team has submitted a file. STORAGE: the submissions hold fictional data only, but keep them where ILCDB approves, with the other scores.

TIME: 5 minutes. RETRIEVAL FIRST: before you reveal this slide, black the screen or leave the previous slide up, and ask the room to call out this afternoon's memory phrases. Then reveal and check. SAY each one with its action. The house: find and remove weaknesses; no weakness, no risk. People, Process, Technology: check all three, not only technology. Four questions: ask them about any process before it changes. STRIDE: ask each letter at every trust boundary. 5 by 5: likelihood times impact; treat Critical and High first. TARA: choose one treatment for every risk, with an owner. SLAM: then pause, verify through a known number, and report. 1326: the government's 24/7 scam hotline, alongside CICC ScamSafe; incidents at work go to your IT unit or DPO. CHECK YOURSELF 2.3, as spaced recall: What does SLAM stand for? Why verify through a number you already know? (The scammer controls any number or link in the message.) Where should a citizen report a scam call? (Hotline 1326, or CICC ScamSafe.) Name one process control that stops a fake bank-detail change. (A call-back to a number already on file, plus a second approver.)




TIME: 6 minutes (about 3 for questions and 3 for the Quiz 2 review). Start with the parking-lot questions; online, the co-host reads them from the chat. QUIZ 2 REVIEW: open the form's summary, pick the two or three items most people missed, and explain each with its desk card phrase. Then release the scores. COMMON QUESTIONS AND SHORT ANSWERS: (1) Do we need special software for threat modeling? No. Paper, a whiteboard or any drawing tool works; the thinking matters, not the tool. (2) Who in our office should own a risk? The person who manages the process or system, named in the register, with the head of office approving any risk that is accepted. (3) Can we scan our own office systems to find weaknesses? Only with written authority from the head of office, and only by authorized staff or contractors; without authority it can be illegal access under RA 10175. (4) Is a vendor's CVSS score enough? It tells you technical severity; the impact on your office decides the order of fixing. (5) What if someone already clicked a phishing link? Report it to IT or the DPO at once, follow IT's instructions, and change the password from a different, safe device. If a question needs a legal opinion, say so and refer it to the DPO or the NPC. Do not guess.

TIME: 4 minutes. SAY: Today we learned what can go wrong. This morning: who attacks offices like ours, and what the law expects. This afternoon: where the weaknesses are, how to predict attacks, and how to spot the tricks aimed at people. Tomorrow we fix things. Morning, Module 3: security controls and data protection, including firewalls, encryption, MFA and access control, then a team workshop; it is not graded, but completion is recorded. Afternoon, Module 4: endpoint security and safe digital workflows, then an individual audit of a training web application, worth 20 percent. It is designed so that non-IT participants can do it: you check and record things anyone can see on screen. DATES: face-to-face, Thursday 22 October; online, Tuesday 27 October. BRING: face-to-face participants bring a laptop with a current browser; online participants join a few minutes early to test their connection. REMIND: the grace period for today's risk assessment runs until 8:00 AM tomorrow, for connection problems only. BRING IT HOME: tonight, pick one process in your own office and ask the four questions in your head; nothing to write or submit. Thank everyone and close Day 1.